

MonSTAR

User data handling statement

Report for the Monash Student Association

By Jenul Ferdinand WIRED Monash

Jenul Ferdinand

27 September 2026

Contents

1	Overview	1
1.1	About MonSTAR	1
1.2	About this statement	1
1.3	Summary	1
2	What we collect	1
2.1	Account data	1
2.2	Reviews, votes and notifications	2
2.3	Analytics, cookies and browser storage	2
3	Where the data lives	3
3.1	Encryption	3
4	Who can see the data	4
4.1	The public	4
4.2	Signed-in users	4
4.3	MonSTAR admins	4
4.4	Infrastructure access	4
5	How we protect it	5
5.1	Sign-in	5
5.2	Sessions	5
5.3	Permissions and secrets	6
5.4	Responding to a breach	6
6	How long we keep it	6
6.1	Retention	6
6.2	Deleting an account	6
7	Users' control over their data	7
8	Known gaps	7

1 Overview

1.1 About MonSTAR

MonSTAR (monstar.wired.org.au) is a unit review site for Monash University students. The Projects Team at WIRED Monash, the student society of the Faculty of Information Technology, builds and runs it. Anyone can read unit pages and reviews without an account. Signed-in users can write reviews, like or dislike other people's reviews, and get a notification when someone likes theirs.

Only Monash accounts can sign in: student addresses of the form `abcd1234@student.monash.edu` and staff addresses of the form `first.last@monash.edu`. Google handles sign-in. MonSTAR has not offered password sign-in since February 2025.

1.2 About this statement

This statement sets out what personal data MonSTAR collects, why it needs it, where the data lives, who can see it, how we protect it, how long we keep it, and how users can see, correct or delete it. We organised it around the questions that privacy frameworks such as the Australian Privacy Principles and the GDPR ask of a service. It describes the system and makes no legal assessment. Users can read a shorter version on the site's privacy page, monstar.wired.org.au/privacy, which the footer and the sign-in page link to.

We wrote it from MonSTAR's source code, which is public at github.com/wiredmonash/monstar, so you can check any claim here against the code. It reflects commit `f70f0af` on the `main` branch. A few facts, such as hosting regions, come from the running services instead.

1.3 Summary

- MonSTAR keeps a small account record: Monash email address, Google account ID, username, profile picture and an admin flag. It does not ask for phone numbers, postal addresses, student ID numbers, dates of birth or payment details, and it discards the name on the Google account.
- Reviews are public. Each one shows its author's username and profile picture, which default to the student's authcate and Google profile photo. Users can change both.
- Public pages and API responses show no account data beyond the username and profile picture. Email addresses stay private.
- MongoDB Atlas holds the data and Vercel runs the site, both in Sydney. Cloudinary stores uploaded profile pictures in the United States (Section 3).
- Users can delete their account from their profile page. MonSTAR deletes their reviews, notifications, votes and uploaded picture in the same step (Section 6).
- Section 8 lists the gaps we found while writing this statement.

2 What we collect

2.1 Account data

MonSTAR creates an account the first time someone signs in. Google sends a signed token that includes the account's email address, account ID, name and profile photo. MonSTAR keeps the fields in Table 1 and discards the name.

Data	Source	Why we keep it	Who can see it
Email address	Google sign-in	Limit sign-in to Monash accounts and find the account at each sign-in	The user and admins
Google account ID	Google sign-in	Link the Google account to the MonSTAR account	No one; the API never returns it
Username	The part of a student email before the @ (the authcate), or the first name in a staff email	Show who wrote a review	Public
Profile picture	A link to the Google profile photo, or a picture the user uploads	Show next to the user's reviews	Public
Admin flag	Set by MonSTAR	Grant moderation rights	The user and admins
Liked and disliked reviews	The user's votes	Let each user vote once per review	The user and admins
Notifications	Created when someone likes the user's review	Tell the user who liked it	The user
Session token hash	Created at sign-in	Keep the user signed in (Section 5.2)	No one

Table 1: Fields in a MonSTAR account.

The record also holds housekeeping fields: a flag for Google sign-in and links to the user's reviews and notifications. People with access to the database itself can read every field (Section 4.4).

Because the default username is the student's authcate, anyone who can search the Monash directory can find out who wrote a review until the student changes it. Users can change their username and upload a different picture from their profile page.

2.2 Reviews, votes and notifications

A review holds a title, the review text, the semester and year the student took the unit, an optional grade (HD, D, C, P or N), four ratings from 0 to 5, like and dislike counts, and the times it was created and last edited. Reviews are public and show the author's username and profile picture.

Like and dislike counts are public; the list of reviews a user voted on is private. Liking a review sends its author a notification with the liker's username and profile picture, so authors can see who liked their reviews. Dislikes send no notification.

2.3 Analytics, cookies and browser storage

MonSTAR uses Vercel Web Analytics to count page views. It sets no cookies. For each page view Vercel records the time, the page address, the referring site, a location derived from the request (country, region and city), and the device type, operating system and browser. Profile page addresses reach Vercel with the username replaced by a placeholder. Vercel tells visitors apart with a hash of the request, discards that hash after 24 hours, and shows us only aggregate figures.¹

¹Vercel, *Privacy and Compliance* (Web Analytics), <https://vercel.com/docs/analytics/privacy-policy>.

The site sets two cookies, both for sign-in (Section 5.2). It also keeps display preferences for the unit list, such as sort order and filters, in the browser’s local storage. MonSTAR does not store those preferences on its servers.

3 Where the data lives

Figure 1 shows MonSTAR’s parts and the outside services they talk to. Table 2 lists the user data each service handles.

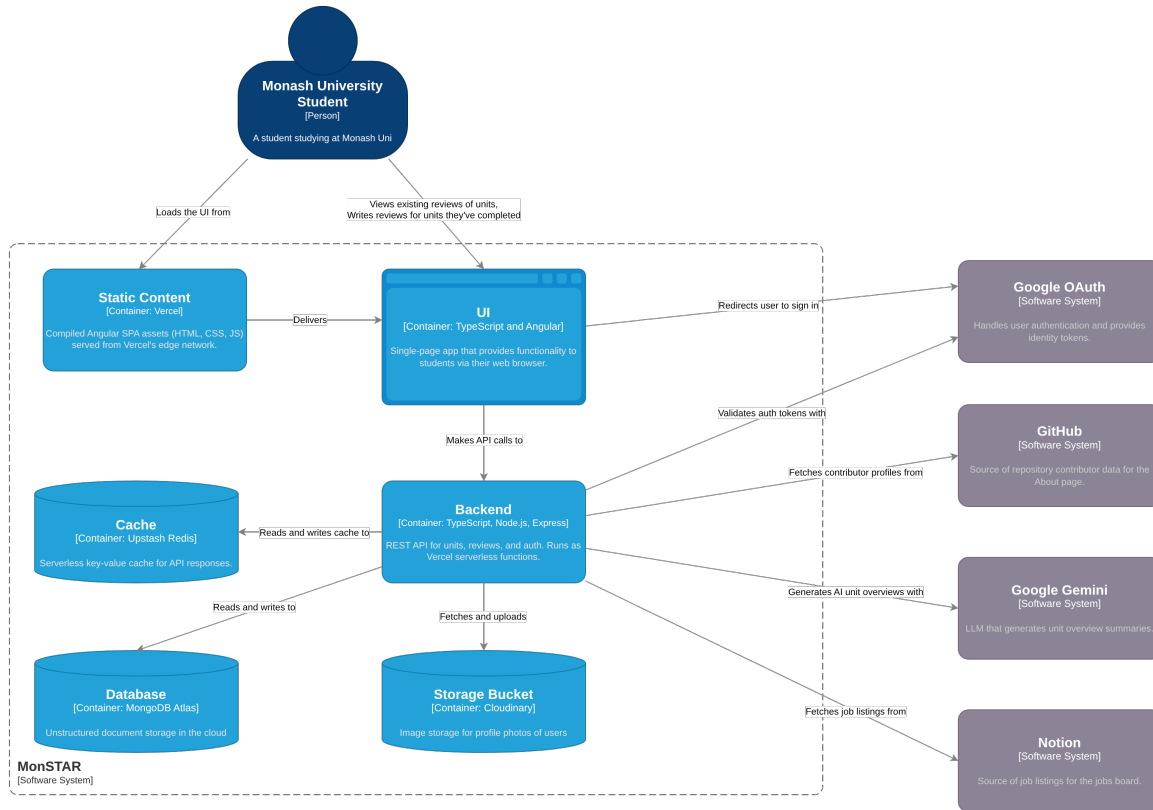


Figure 1: MonSTAR’s containers and the outside services it uses.

The AI overview prompt carries no account details, but review text is whatever the author wrote, so it can mention people. Nothing calls Gemini automatically, and the deployed site has no route that can. A developer regenerates overviews by hand, running the backend on their own machine against the production database. MonSTAR uses the Gemini API’s free tier, where Google’s terms let it use prompts to improve its products and allow human reviewers to read them.²

Two more services feed MonSTAR but hold no user data. Notion supplies the listings on the jobs board, and GitHub supplies the contributor list on the About page.

3.1 Encryption

The site redirects plain HTTP to HTTPS and sends a Strict-Transport-Security header, so browsers use HTTPS on every later visit. Atlas requires TLS on every database connection and

²Google, *Gemini API Additional Terms of Service*, <https://ai.google.dev/gemini-api/terms>.

Service	Role	User data it handles	Region
MongoDB Atlas	Main database	Everything in Section 2	AWS Sydney (ap-southeast-2)
Vercel	Serves the site, runs the backend API and counts page views	All API traffic in transit, server logs, page-view analytics	Sydney (syd1)
Cloudinary	Stores uploaded profile pictures	Pictures users upload	United States (Cloudinary's default)
Google Sign-In	Confirms who is signing in	Email address, account ID, name and photo, sent at sign-in	Google (global)
Google Gemini API	Writes the AI overview on each unit page	Each unit's review titles, text, semesters, years, grades and ratings; no usernames, emails or account IDs	Google (global)
Upstash Redis	Caches popular units and the jobs board	Review titles, text and ratings for the most-reviewed units; no author details	AWS Sydney (ap-southeast-2)

Table 2: Outside services that store or process user data.

encrypts its storage and snapshots at rest with AES-256.³

4 Who can see the data

4.1 The public

Anyone can read reviews, like and dislike counts, and public profiles without signing in. A public profile shows a username, a profile picture and that user's reviews. The public API returns the same fields. It never returns email addresses, Google account IDs, vote lists or session data.

4.2 Signed-in users

A signed-in user can see their own email address, votes and notifications. They can change their username and profile picture, edit or delete their own reviews, and delete their account. They cannot change anyone else's data.

4.3 MonSTAR admins

Accounts with the admin flag moderate the site. One account has it: Jenul Ferdinand's. Admins can list every user, including email addresses, change usernames, and edit or delete any review or account. The server checks admin rights on every admin request.

4.4 Infrastructure access

Anyone who can log in to MonSTAR's Atlas, Vercel, Cloudinary, Upstash or Google Cloud accounts can reach the data those services hold (Table 3). So can anyone with the production database connection string, which developers keep on their own machines for tasks such as

³MongoDB, *Configure Security Features for Clusters*,
<https://www.mongodb.com/docs/atlas/setup-cluster-security/>.

regenerating AI overviews. That string's database user can read and write every database on the cluster.

Preview deployments, which Vercel builds for each branch except Dependabot's, use the same database and secrets. Vercel's login protection limits who can open them, and builds from forks need our approval. Anyone who can push a branch to the repository can still run code against production data.

Account	Who has access
GitHub repository	5 admins and 9 other accounts can push; 4 can only read. The WIRED Monash organisation requires two-factor authentication.
Vercel	The club's shared account (owner), which signs in with a passkey, and one team member. Both use two-factor authentication.
Upstash	Managed through Vercel's storage integration.
MongoDB Atlas	Two organisation owners, one project owner, and one account that can build MongoDB Charts from the data. The organisation does not require multi-factor authentication.
Cloudinary	Only Jenul Ferdinand.
Google Cloud (sign-in client and Gemini key)	Only Jenul Ferdinand.

Table 3: Who can log in to the services that hold user data.

5 How we protect it

5.1 Sign-in

- Google handles authentication. The backend checks each Google token's signature and confirms Google issued it for MonSTAR before trusting it.
- The backend then checks the email address against the Monash student and staff formats and rejects any other address.
- MonSTAR has no password sign-in, and no account in the database holds a password.

5.2 Sessions

After sign-in the backend sets two cookies:

- `access_token`, a signed token that identifies the user on each request and expires after 15 minutes;
- `refresh_token`, a random 40-byte value that lasts 180 days and lets the browser get a new access token without signing in again.

The database stores only a SHA-256 hash of the refresh token, so someone holding a copy of the database still cannot sign in as a user. Each refresh swaps the refresh token for a new one, and signing out deletes the stored hash. Both cookies are Secure, so browsers send them only over HTTPS, and HttpOnly, so page scripts cannot read them. They are also SameSite=Strict, so browsers do not send them with requests that start on other sites.

5.3 Permissions and secrets

- The server lets only a review’s author or an admin edit or delete it, and only the account owner or an admin change a username or delete an account.
- API keys and the token-signing secret live in Vercel’s environment settings. The public repository holds only a template with placeholder values.
- Atlas accepts database connections from any network address, because Vercel’s functions have no fixed addresses on our plan. The database password is the barrier.

5.4 Responding to a breach

Whoever suspects a breach tells Jenul Ferdinand straight away. We contain it first, by rotating the exposed secrets and cutting off access, then work out what data was exposed. We tell MSA within 72 hours of confirming a breach, and email affected users as soon as we know who they are.

6 How long we keep it

6.1 Retention

MonSTAR keeps account data, reviews, votes and notifications until the user deletes them or their account. Only sessions expire on their own: access tokens after 15 minutes and refresh tokens after 180 days.

Some copies outlast the original:

- The popular-units cache in Upstash holds review text and ratings, without author details, for up to one week.
- Each unit’s AI overview summarises the reviews the unit had when a developer last regenerated it. A deleted review still shapes that summary until the next regeneration.
- The backend logs internal user IDs, not names or emails, when it deletes an account. Vercel keeps runtime logs for one hour on our plan.⁴

The database has no backups. It runs on Atlas’s free tier, which does not take them, so deleted data leaves no copy behind, and data lost by mistake cannot be restored (Section 8).

6.2 Deleting an account

Users delete their account with the *Delete account* button on their profile page, then confirm. MonSTAR then:

1. deletes all of the user’s reviews and recalculates the average ratings of the units they reviewed;
2. deletes the notifications addressed to the user;
3. removes the user’s likes and dislikes from other people’s reviews;
4. deletes the user’s uploaded profile picture from Cloudinary, if they uploaded one;
5. deletes the account record.

⁴Vercel, *Runtime Logs*, <https://vercel.com/docs/logs/runtime>.

Steps 1 to 3 run in one database transaction, so if any of them fails, MonSTAR deletes nothing and keeps the account. Notifications the user caused by liking other people's reviews survive the deletion. They stay in those people's inboxes, with the user's username and picture link (Section 8).

7 Users' control over their data

Table 4 shows how users see, correct and delete their data.

Request	How users do it
See their data	Signed-in users see their profile, reviews and notifications on the site. For a full copy, they email monstarapp@gmail.com from their Monash address, and we reply within 30 days with their account record, reviews and notifications.
Correct it	Change their username and picture on the profile page, and edit their reviews at any time.
Delete it	Delete single reviews, or the whole account (Section 6).
Ask a question or complain	Email monstarapp@gmail.com, the contact on the site's terms page.

Table 4: How users exercise control over their data.

8 Known gaps

We found these while preparing this statement.

1. **Identifying default usernames.** New student accounts take the authcate as their public username and the Google profile photo as their picture (Section 2). In September 2026, 553 of 646 student accounts still used their authcate.
2. **Production secrets reach beyond production.** Developers keep the production database connection string locally, and its database user can read and write every database on the shared cluster. Vercel also gives every branch preview the production database connection string and token-signing secret, so all 14 accounts that can push to GitHub can reach production data. Dependabot's branches no longer build previews, so its dependency updates reach these secrets only after someone reviews and merges them. Issue #331 covers a least-privilege database user. Previews also need their own database and secrets, and the GitHub, Vercel and Atlas access lists need a review.
3. **No database backups.** The free Atlas tier takes none, so an accidental deletion or a bad write cannot be undone. A scheduled export or a paid tier would fix this.
4. **Notifications outlive the liker's account.** Deleting an account leaves its "liked your review" notifications in other users' inboxes (Section 6).
5. **Gemini free tier.** Google may use review text sent for AI overviews to improve its products (Section 3).
6. **No rate limits on public endpoints.** Someone could download every public review with its author's username. Issues #328 and #329 in our repository track the fix.